COMPTIA SECURITY+ SY0-701 | DOMAIN 1 · GENERAL SECURITY CONCEPTS (12%)

Security+ 1.4 · Hashing & Digital Signatures

Mestre CyberSec · **Lesson 1.4 — Hashing & Digital Signatures** (10:24) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Hash = impressão digital mão única: SHA-256/SHA-3 padrão; MD5/SHA-1 quebrados. Assinatura digital = cifrar o hash com a chave PRIVADA — qualquer um valida com a pública. Garante integridade + autenticidade + non-repudiation (3 objetivos).

💡 Key Exam Highlights & Critical Concepts

- SHA-256 padrão; MD5/SHA-1 quebrados (collision)
- Assinatura = hash cifrado com chave PRIVADA de quem assina
- Avalanche effect: 1 bit mudou = hash inteiro mudou

🎯 Exam Tips & Typical CompTIA Scenarios

- 'provides integrity but not confidentiality' = hash
- 'cannot deny that they signed' = digital signature (non-repudiation)

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 1.4 — Hashing & Digital Signatures)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Hash Function (Hashing) (N/A)

A one-way cryptographic function that transforms data of any size into a fixed-length digest; it provides integrity but not confidentiality or authentication by itself.

⚠️ ***Exam Trap:*** *Se a prova disser 'integridade, mas não confidencialidade', a resposta é hash. Hashes não são criptografia reversível.*

• SHA-256 (Secure Hash Algorithm 256-bit)

A SHA-2 hashing algorithm that produces a 256-bit digest and is the current standard for integrity and digital signatures in CompTIA exam scenarios.

⚠️ ***Exam Trap:*** *Escolha SHA-256 quando a questão pedir hash seguro e atual; MD5 e SHA-1 são considerados quebrados.*

• SHA-3 (Secure Hash Algorithm 3)

A newer NIST hash standard based on Keccak, used as a secure alternative to SHA-2 and not vulnerable to MD5/SHA-1 collision attacks.

⚠️ ***Exam Trap:*** *SHA-3 é padrão seguro, mas SHA-256 ainda é a escolha mais comum em questões; ambos são aceitos como fortes.*

• MD5 (Message Digest 5)

An older 128-bit hashing algorithm considered broken due to practical collision attacks; it should not be used for integrity or digital signatures.

⚠️ ***Exam Trap:*** *Se a questão mencionar MD5, geralmente é a resposta errada/fraca; indique colisões e obsolescência.*

• SHA-1 (Secure Hash Algorithm 1)

A 160-bit hashing algorithm deprecated because collisions have been demonstrated; it is no longer trusted for digital signatures or integrity.

⚠️ ***Exam Trap:*** *Assim como MD5, SHA-1 é considerado quebrado; prefira SHA-256 ou SHA-3.*

• **Collision (N/A)**

A situation where two different inputs produce the same hash digest; it breaks integrity guarantees and is why MD5 and SHA-1 are deprecated.

⚠️ ***Exam Trap:*** *Palavra-chave 'collision' aponta para algoritmo de hash quebrado (MD5/SHA-1), não para criptografia simétrica.*

• **Digital Signature (N/A)**

A cryptographic mechanism where a hash of a message is encrypted with the sender's private key; verification uses the sender's public key and provides integrity, authentication, and non-repudiation.

⚠️ ***Exam Trap:*** *'Cannot deny that they signed' = non-repudiation, provided by digital signature. Lembre: chave privada assina, chave pública valida.*

• **Avalanche Effect (N/A)**

A property of strong hashing where a small change in input, even one bit, produces a completely different hash digest.

⚠️ ***Exam Trap:*** *Se a questão mostrar dois hashes totalmente diferentes para entradas quase iguais, é o avalanche effect.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Cryptographic Hash Function & The Avalanche Effect

🏠 **Real-World Analogy:** Think of an automated baking machine. You drop flour, eggs, sugar, and milk into the hopper. The machine processes the mixture and outputs a small pastry weighing precisely 256 grams. This is a strict ONE-WAY mathematical operation: anyone can insert ingredients to produce the pastry, but it is physically impossible to shove the finished pastry backwards into the machine to reconstruct unbroken raw eggs! Now consider the Avalanche Effect: if you alter a single grain of sugar in the initial recipe, the resulting pastry pops out glowing bright purple with an entirely unrecognizeable chemical signature. The cryptographic hash represents that file's unique, irreversible mathematical fingerprint.

🔍 **Root Cause & Background:** Re-transmitting a 50-gigabyte database backup across wide-area networks simply to check if an unauthorized alteration occurred squanders bandwidth. A cryptographic hash function (such as SHA-256) condenses arbitrary inputs into an immutable, fixed-size 256-bit digest, enabling instant verification of data integrity.

🛡️ **GRC Auditor Perspective:** GRC auditors mandate cryptographic hashing across forensic workflows and system integrity baselines. All digital evidence seized during an incident response investigation must have its SHA-256 checksum calculated immediately and documented in the official Chain of Custody log. Any discrepancy in a single character invalidates the evidence in legal court proceedings.

⚠️ **How CompTIA Tests This:** CompTIA Exam Triggers: 'one-way cryptographic function utilized strictly to verify data integrity' -> Hash function; 'changing a single character in the input completely alters the output digest' -> Avalanche effect; 'guarantees integrity but does NOT provide confidentiality' -> Hash.

📌 Hash Collisions & Deprecation of MD5 / SHA-1

🏠 **Real-World Analogy:** Imagine two completely unrelated human beings born with identical physical fingerprints. In biometric forensics, this would destroy criminal investigations. In cryptography, when two distinct documents (for example, a legitimate $100 invoice and a fraudulent $1,000,000 payment demand) generate the EXACT same hash digest, this event is called a 'Collision'. Once researchers demonstrated practical collision generation within minutes on commodity hardware, the underlying algorithms collapsed! Consequently, MD5 and SHA-1 were formally deprecated and banned.

🔍 **Root Cause & Background:** The universe of prospective inputs is infinite, but the digest length is strictly bounded (128 bits for MD5; 160 bits for SHA-1). Under the Pigeonhole Principle and Birthday Paradox, mathematical collisions are inevitable. Modern algorithms like SHA-256 and SHA-3 expand the keyspace so vastly that computing a collision requires more energy than exists in the known universe.

🛡️ **GRC Auditor Perspective:** Execute automated configuration scans to detect legacy cryptographic remnants. Auditors flag any digital certificate, software packaging manifest, or authentication hash relying on MD5 or SHA-1 as non-compliant, mandating immediate remediation to SHA-256 (SHA-2) or SHA-3 per NIST and PCI-DSS mandates.

⚠️ **How CompTIA Tests This:** CompTIA Exam Triggers: 'two different inputs yield the identical digest value' -> Collision; 'legacy hash algorithms proven susceptible to collision attacks' -> MD5 and SHA-1; 'secure modern replacement standard' -> SHA-256 / SHA-3.

📌 Digital Signatures & The Royal Wax Seal

🏠 **Real-World Analogy:** Imagine a royal royal decree dispatched from the King to front-line generals. To ensure no impersonator sends forged commands and no bandit alters tactical instructions, the King executes three steps: 1) He computes a cryptographic digest of the order (the Hash). 2) He presses his unique personal gold signet ring worn solely on his finger (the Sender's Private Key) into hot wax sealing that hash to the parchment (the Digital Signature). Upon arrival, the general verifies the wax using the public royal heraldry crest displayed in every town hall (the Sender's Public Key) while recalculating the text hash. A successful match proves three critical assurances simultaneously: 1) The decree originated exclusively from the King (Authentication); 2) Not a single word was altered in transit (Integrity); 3) The King cannot legally deny issuing the military order (Non-repudiation).

🔍 **Root Cause & Background:** Hashing in isolation merely guarantees message integrity; it cannot provide origin authentication (an active adversary could intercept a file, modify its contents, compute a fresh hash, and transmit both). A Digital Signature fuses hashing with asymmetric cryptography by encrypting the digest using the sender's private key, binding author identity irrevocably to the payload.

🛡️ **GRC Auditor Perspective:** Mandate cryptographic code signing across software deployment pipelines (Code Signing certificates for executables, firmware, and container images). For governance audits, verify digital signatures on financial ledger modifications and corporate contracts to ensure non-repudiation and enforce legal accountability.

⚠️ **How CompTIA Tests This:** CompTIA Exam Triggers: 'sender encrypts a message hash using their private key' -> Digital Signature; 'which three security requirements are achieved simultaneously by digital signatures' -> Integrity, Authentication, Non-repudiation; 'recipient verifies a digital signature using' -> Sender's Public Key.

📌 Integrity vs. Confidentiality (Hashing Does NOT Encrypt)

🏠 **Real-World Analogy:** Imagine a commercial delivery van constructed with entirely transparent glass cargo panels. Every pedestrian on the sidewalk can clearly inspect the 50 boxed computers loaded inside (zero confidentiality). However, across the rear cargo doors, the warehouse affixed an inspection seal with a unique serial number (the Hash). If a dishonest driver opens the doors to steal a computer, the seal breaks and the serial verification fails upon arrival (Integrity violation detected instantly). The hash is the tamper-evident numeric seal; it never conceals the cargo from view.

🔍 **Root Cause & Background:** A pervasive novice misconception assumes that hashing encrypts or conceals data. Hashing merely produces a fixed validation summary. For password storage, raw hashes are acutely vulnerable to precomputed Rainbow Table lookups unless combined with a cryptographically random Salt and computationally intensive key stretching.

🛡️ **GRC Auditor Perspective:** Audit authentication database credential architectures. Issue high-risk findings for systems storing credentials in plaintext or fast unsalted hashes (such as bare SHA-256). Mandate salted, memory-hard key derivation algorithms (Argon2id, bcrypt, or PBKDF2) to resist offline dictionary brute-forcing.

⚠️ **How CompTIA Tests This:** CompTIA Exam Triggers: 'ensures that an ISO image or file has not been tampered with while leaving content unencrypted' -> Hashing; 'random string concatenated with a password prior to hashing to defeat rainbow table attacks' -> Salt.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Mathematically verifies that a downloaded software installer was not modified or infected by malware	**Cryptographic Hash (SHA-256 / Integrity)**
Modifying a single bit in an input file drastically changes the entire resulting hash string	**Avalanche Effect**
Two distinct input files producing the exact same hash output, compromising algorithm security	**Hash Collision**
Message digest encrypted with the sender's private key providing integrity, authenticity, and non-repudiation	**Digital Signature**
Cryptographic key used by a recipient to verify the validity of an incoming digital signature	**Sender's Public Key**
Random data appended to user passwords prior to hashing to defeat precomputed rainbow tables	**Salt (Password Salting)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A systems administrator at a healthcare provider downloads an Ubuntu server ISO from the vendor's official website. Before installing it on a production host, the administrator wants to confirm that the file was not altered during download or replaced by a malicious copy on a mirror. Which action BEST accomplishes this goal?

A) Compute the SHA-256 digest of the downloaded ISO and compare it with the digest published by the vendor

B) Confirm that the ISO file size matches the size listed on the download page

C) Scan the ISO with the endpoint antivirus agent and confirm that no malware was detected

D) Verify that the TLS certificate of the download site was issued by a trusted certificate authority

QUESTION 2 · EXAM SCENARIO

During a security assessment of a legacy payroll application, an analyst discovers that the application verifies the integrity of exported reports using MD5 digests. The analyst reports this as a high-risk finding. Which statement BEST explains the technical weakness of this design?

A) MD5's collision resistance is broken, so two different reports can produce an identical digest

B) MD5 uses a 512-bit key that is too short to resist modern brute-force hardware

C) MD5 is a symmetric algorithm, so the verification key must be shared with the recipient

D) MD5 produces a variable-length digest that cannot be reliably compared across systems

QUESTION 3 · EXAM SCENARIO

A financial analyst receives an email contract from a business partner containing a digital signature. To validate the signature and confirm both the integrity of the message and the identity of the sender, which key must the analyst use?

A) The partner's public key

B) The partner's private key

C) The analyst's own private key

D) The analyst's own public key

QUESTION 4 · EXAM SCENARIO

A legal department requires that software release approvals be cryptographically bound to the individual engineer who approved them, so that an engineer cannot later deny having authorized a release. Which control BEST satisfies this requirement?

A) Digitally signing each approval with the approving engineer's private key

B) Encrypting each approval with a shared AES key held by the entire engineering team

C) Generating an HMAC of each approval using a shared secret stored on the build server

D) Storing a hash of each approval in a read-only database table

QUESTION 5 · EXAM SCENARIO

A malware analyst observes that two completely different executable files, one benign and one malicious, produce exactly the same SHA-1 digest value when analyzed by the lab tooling. The analyst escalates this finding to the security team. Which cryptographic event has occurred?

A) A collision in the hash function

B) A truncation error introduced by the analyst's hashing tool

C) A successful private key recovery against the signing certificate

D) An offline dictionary attack against the executable's embedded credentials

QUESTION 6 · EXAM SCENARIO

A developer changes a single character in a configuration file and then regenerates its SHA-256 digest for the deployment manifest. The security engineer notices that roughly half of the digest bits changed compared with the previous version. Which property of cryptographic hash functions does this behavior illustrate?

A) The avalanche effect

B) The birthday paradox

C) Key stretching

D) Forward secrecy

QUESTION 7 · EXAM SCENARIO

A software company distributes an internally developed desktop client through its public website. Customers must be able to confirm both that the binary originated from the company and that it has not been modified since it was built. Which mechanism should the company implement to provide both assurances to customers?

A) Code signing the binary with a certificate whose private key is held in a hardware security module

B) Publishing the MD5 checksum of the binary next to the download link

C) Compressing the binary with a password-protected archive

D) Publishing the SHA-256 digest of the binary over an unauthenticated HTTP channel

QUESTION 8 · EXAM SCENARIO

A security architect is documenting the security services delivered by a component that only computes SHA-3 digests of messages and stores them. The architect must accurately state which security goal is NOT provided by this component. Which goal should be listed as not provided?

A) Confidentiality

B) Integrity

C) Detection of accidental modification

D) Provision of a fixed-length representation of variable-length data

QUESTION 9 · EXAM SCENARIO

Two internal servers exchange inventory messages protected with an HMAC derived from a pre-shared key that both servers hold. A dispute later arises over which server actually sent a specific message. Why does the HMAC fail to resolve this dispute?

A) Because both servers hold the same shared secret, either one could have generated the HMAC, so no non-repudiation exists

B) Because HMAC uses a hash function, the message contents cannot be recovered to prove what was sent

C) Because the pre-shared key is symmetric, it is mathematically infeasible to compute an HMAC in real time

D) Because HMAC digests are truncated to 128 bits, the sender identity is lost during transmission

QUESTION 10 · EXAM SCENARIO

A government contractor must select a hash algorithm for a new system that processes controlled unclassified information. The contract requires a FIPS-approved algorithm that provides the strongest available resistance to length-extension and collision attacks and does not rely on the Merkle-Damgård construction. Which algorithm family should the contractor select?

A) SHA-3

B) SHA-1

C) MD5

D) RIPEMD-160

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Compute the SHA-256 digest of the downloaded ISO and compare it with the digest published by the vendor

A cryptographic hash acts as a one-way fingerprint of the file. Recomputing the SHA-256 digest locally and comparing it to the vendor-published value detects any single-bit modification made in transit or by a mirror. File size and antivirus scanning can both be defeated by a modified file, and a valid TLS certificate only protects data in transit to that site — it does not prove the stored file itself is unmodified.

Question 2: Option A — MD5's collision resistance is broken, so two different reports can produce an identical digest

MD5 is a hash function, not an encryption algorithm, and it has been shown to be vulnerable to practical collision attacks: an attacker can craft two different inputs that yield the same MD5 digest. This destroys the integrity guarantee, because a tampered report could carry the same digest as the original. MD5 does not use keys, and it always produces a fixed 128-bit output.

Question 3: Option A — The partner's public key

In a digital signature scheme, the signer hashes the message and encrypts the hash with their own private key. Any recipient validates the signature by decrypting the hash with the signer's widely distributed public key and comparing it with a freshly computed hash of the message. Possession of the signer's public key is what makes verification possible without exposing the signing secret.

Question 4: Option A — Digitally signing each approval with the approving engineer's private key

Non-repudiation requires that the proof of origin be tied to one party's exclusive secret. A digital signature created with an individual's private key can be validated by anyone using that person's public key, and only the holder of the private key could have produced it. Symmetric controls such as shared AES keys or HMAC secrets do not provide non-repudiation, because every holder of the shared secret could have generated the same value. A plain hash proves integrity only, with no identity binding.

Question 5: Option A — A collision in the hash function

A collision occurs when two distinct inputs produce the same hash output. SHA-1 has been demonstrated to be collision-prone, which is why it is deprecated for integrity and signature use. Hash truncation by a tool is a configuration issue rather than a cryptographic event, and neither key recovery nor dictionary attacks relate to two different files sharing a digest.

Question 6: Option A — The avalanche effect

The avalanche effect is the property whereby a tiny change in the input (even one bit) produces a drastically different output digest, with about half of the bits flipping. This is what makes hashes useful for detecting tampering: an attacker cannot incrementally modify a file while keeping the digest similar. The birthday paradox relates to collision probability, key stretching slows down brute-force guessing of passwords, and forward secrecy protects past session keys.

Question 7: Option A — Code signing the binary with a certificate whose private key is held in a hardware security module

Code signing uses a digital signature generated with the publisher's private key; customers validate it with the publisher's public key from the code-signing certificate. This simultaneously proves integrity and authenticates the source, and because the signing key is asymmetric it supports non-repudiation. A published checksum alone proves integrity but not origin, MD5 is collision-broken, and shipping the digest over an unauthenticated channel would let an attacker replace the digest along with the binary.

Question 8: Option A — Confidentiality

Hashing is a one-way transformation that supports integrity checking: any change to the message changes the digest. However, it performs no encryption, so the message contents remain readable to anyone with access, meaning confidentiality is not provided. Integrity, change detection, and producing a fixed-size digest from arbitrary-length input are all inherent properties of a hash function.

Question 9: Option A — Because both servers hold the same shared secret, either one could have generated the HMAC, so no non-repudiation exists

HMAC provides integrity and authenticity between parties that share a secret key, but it cannot establish non-repudiation. Since both servers possess the identical key, either could have produced the value, so a third party cannot

attribute a specific message to one of them. Message confidentiality is irrelevant to this dispute, HMAC computation is efficient, and digest length is not the reason attribution fails.

Question 10: Option A — SHA-3

SHA-3 is a NIST-approved standard built on the sponge construction rather than Merkle-Damgård, which makes it inherently resistant to length-extension attacks and provides strong collision resistance. SHA-1 and MD5 are both deprecated due to demonstrated collisions, and RIPEMD-160 is neither FIPS-approved nor as collision-resistant as modern SHA-2/SHA-3 options.